



UNIVERSIDAD NACIONAL EXPERIMENTAL DE GUAYANA

VICERRECTORADO ACADÉMICO

COORDINACIÓN DE INGENIERÍA EN INFORMÁTICA

INGENIERÍA DE SOFTWARE II



ACTIVIDAD II PRODUCTO IV:

“Risk Storming Simulado para Fintech Mobile (Serverless + API IA)”

Docente:

Félix Marquez

Integrantes:

Gómez Andrés V-31.085.717

Ramírez Alexmary V-31.809.930

Silva José V-30.810.283

Vallenilla Daniel V-31.159.105

2. Registro de Riesgos (Risk Register) Híbrido y Gobernanza Ágil

1. Registro de Riesgos (Risk Register) Híbrido de Una Sola Página

Este diseño responde a la necesidad de mantener un formato compacto, transparente y accesible para auditorías normativas, eliminando las hojas de cálculo extensas y desactualizadas.

FORMATO DE HOJA ÚNICA / DASHBOARD DE AUDITORÍA DE RIESGOS

Proyecto: App Móvil Fintech Créditos | Iteración / Sprint: Sprint 12

Fecha de Actualización: 16 de Septiembre de 2026 | Facilitador de Riesgos: Scrum Master / Lead Arch

ID	Descripción del Riesgo	Prob. (1-5)	Imp. (1-5)	Risk Score	Dueño del Riesgo (Risk Owner)	Estado Actual	Estrategia & Plan de Respuesta	Artefacto Vinculado en Backlog
RS K-01	Cambio imprevisto de costos o términos de servicio en la API de IA de terceros (ej. aumento de precio por llamada o límites de cuotas).	4	4	16	Product Owner	Activo / Monitorio	Mitigar: Implementar arquitectura de caché, límites de cuota locales y patrón <i>Adapter</i> para fallback a proveedor secundario.	PB-204 (Enable r) / US-108 (Spike)
RS K-02	Inyección de paquetes vulnerables en dependencias Serverless (Ataque a la cadena de suministro).	4	5	20	Tech Lead / DevOps	En Mitigación	Mitigar: Integración de herramienta SCA (Snyk) y bloqueo automatizado de builds en pipeline CI/CD.	SEC-104 (Enable r)

RS K-03	Acoplamiento excesivo y Vendor Lock-in con la infraestructura Serverless del proveedor Cloud.	3	4	12	Arquitectura de Software	Monitoreo	Transferir/Mitigar: Empaquetar la lógica de negocio en contenedores/funciones usando Serverless Framework multiplataforma.	ARCH-45 (Spike)
RS K-04	Sesgos algorítmicos en la evaluación de crédito derivando en rechazos discriminatorios no explicables.	2	5	10	PO / Compliance Legal	Aceptado pasivo	Evitar/Mitigar: Implementar módulo de registro de variables clave y auditoría de decisiones con explicabilidad (XAI).	COMP-12 (Enabler)

2. Mecanismo de Gobernanza Ágil: Mantenimiento del Registro Vivo

Para evitar la burocracia de documentos estáticos, el Registro de Riesgos no se actualiza en reuniones separadas, sino que se integra directamente en las **ceremonias nativas de Scrum**:

1. Sprint Planning (Planificación del Sprint):

- **Dinámica:** El equipo revisa el top de riesgos con mayor *Risk Score* (prioridad alta/crítica).
- **Acción:** Los riesgos no se quedan como conceptos abstractos; se reservan puntos de historia o capacidad de trabajo del Sprint para incluir *Spikes* técnicos o *Enablers* de seguridad directos al *Sprint Backlog*.

2. Daily Standup (Reunión Diaria):

- **Dinámica:** Cuando un desarrollador identifica un impedimento que puede derivar en un nuevo riesgo o cuando una mitigación en curso se retrasa.
- **Acción:** Se actualiza en tiempo real el *Estado* del riesgo en el tablero visual

(Kanban/Jira) mediante etiquetas de alerta de riesgo.

3. Sprint Review (Revisión del Sprint):

- **Dinámica:** Transparencia con los *Stakeholders* y patrocinadores del proyecto.
- **Acción:** El *Product Owner* presenta no solo las características funcionales entregadas, sino también las acciones de mitigación completadas que redujeron la exposición al riesgo del negocio.

4. Sprint Retrospective (Retrospectiva):

- **Dinámica:** Inspección del proceso y de los nuevos vectores de incertidumbre surgidos durante la iteración.
- **Acción:** Se realiza una minisesión de *Risk Storming* de 10 minutos para recalibrar probabilidades e impactos, y para retirar o archivar riesgos cuya amenaza haya desaparecido.

3. Ejemplo de Transformación: De Riesgo a Elemento del Product Backlog

- **Riesgo Identificado (RSK-01):** "La API de Inteligencia Artificial de terceros podría modificar unilateralmente sus costos por consulta o sus términos de servicio, encareciendo insosteniblemente la operación de la aplicación crediticia y bloqueando el servicio".

Transformación en el Backlog:

Este riesgo se descompone en dos artefactos tangibles dentro del **Product Backlog**:

Artefacto A: Research Spike (Investigación y Abstracción Arquitectónica)

- **ID:** SPIKE-IA-01
- **Título:** *[SPIKE] Diseño del Patrón Adapter y Caché de Respuestas para la API de IA Crediticia*
- **Tipo:** Spike / Investigación Técnica
- **Estimación:** 3 Puntos de Historia (Timebox: 2 días)
- **Descripción / Criterios:**
 - Investigar e implementar un patrón de diseño *Adapter / Interface* para desacoplar el core de la aplicación del proveedor actual de IA.
 - Evaluar el impacto de costos y diseñar un mecanismo de almacenamiento en caché (*Redis/DynamoDB*) para solicitudes repetidas o similares, reduciendo las llamadas a la API externa en al menos un 30%.
 - Definir una API secundaria de respaldo (*fallback*) en caso de interrupción o cambio abrupto de costos.

Artefacto B: Enabling User Story (Historia de Habilitación de Gobernanza de Costos)

- **ID:** ENABLER-COST-02
- **Título:** *[ENABLER] Control de Cuotas y Alertas de Facturación para API de Scoring IA*
- **Tipo:** Technical Enabler / Risk Mitigation
- **Estimación:** 5 Puntos de Historia
- **Criterios de Aceptación:**

1. Implementar un middleware de limitación de tasa (*Rate Limiting*) y control de cuota máxima diaria por usuario para evitar consumos desmedidos.
2. Configurar alertas automatizadas (vía AWS CloudWatch / Slack Notifications) cuando el costo mensual estimado de invocaciones a la API supere el 80% del presupuesto asignado.
3. Crear un interruptor de circuito (*Circuit Breaker*) que active una degradación elegante del servicio (evaluación crediticia basada en reglas tradicionales) si la API de IA excede tiempos de respuesta o devuelve errores de cuota.